

10th International Conference of Information and Communication Technology (ICICT-2020)

Compliance analysis of business information system under classified protection 2.0 of cybersecurity

Xin Jiang, Yanqing Ding*, Xiudan Ma, Xumao Li

China Earthquake Networks Center, Beijing 100045, China

Abstract

Classified protection of cybersecurity is an important part of cybersecurity system of China's information system. It is the basic requirement of business system compliance operation, and is also a prerequisite for security assessment and solving information system security problems. This article studies and discusses the management system, infrastructure, protection equipment and other aspects. Analyze the business information system, and sort out the compliance of the information system item by item under classified protection of cybersecurity 2.0. According to the analysis results of the compliance of the information system, the non-compliance is classified according to the difficulty of rectification. The information system is rectified and reformed according to the strategy from easy to difficult. So, in short time, the protection level of information system is improved and the security risk of information system is reduced.

© 2021 The Authors. Published by Elsevier B.V.

This is an open access article under the CC BY-NC-ND license (<http://creativecommons.org/licenses/by-nc-nd/4.0/>)

Peer-review under responsibility of the scientific committee of the 10th International Conference of Information and Communication Technology.

Keywords: Business information system; classified protection; compliance; rectification and reform; security risk

1. Introduction

In 1994, China's network was connected to the Internet. Over the past 26 years, China has rapidly grown into an information-based country, with the largest number of Internet users and the fastest popularization in the world. However, it should be recognized that China has not yet become an information power. The increasing number of Internet users in China not only promotes the development of the network, but also increases the risk of network security and the cost of maintenance [1]. Network attacks have also spread from the traditional Trojan horse and virus to today's precision attack. The security risks faced by information systems in operation are more complex, and the

* Corresponding author. Tel.: +86-150-0125-6229.

E-mail address: geochild@163.com

importance of network security has become increasingly prominent. But the information system type is various, the characteristic is different, therefore needs to carry on the security protection to the information system by different type and different classification.

2. Research Background

The United States is one of the first countries to study information security protection. In 2002, the federal government of the United States promulgated the *Federal Information Security Management Act (FISMA)*. The act divides information systems in the United States into non-national security systems and national security systems. The national security system is classified system, and the non-national security system is non-classified system. The two types of systems implement classified protection respectively. The Office of federal Management and Budget (OMB) is responsible for the supervision of information security policies of non-national security system of federal agencies. Federal agency inspectors or assessment agencies assess implementation and report annually to Congress [2].

Similar to the classified management of the United States, China implements hierarchical protection for classified systems and classified protection for non-classified systems. In 2007, the Ministry of Public Security of PRC, the State Secrets Bureau of PRC and other two ministries and commissions of PRC issued the *Management Measures for Classified Protection of Information Security*, laying the foundation of classified protection 1.0. From 2008 to 2012, a series of classified protection policies and standards were issued successively, which constituted the standard system of classified protection 1.0. On May 13, 2019, three standards, *Information security technology — Baseline for classified protection of cybersecurity*, *Information security technology — Evaluation requirement for classified protection of cybersecurity* and *Information security technology — Technical requirements of security design for classified protection of cybersecurity* (i.e. classified protection 2.0) were officially issued by the State Administration for Market Regulation of PRC and the Standardization Administration of PRC, and formally implemented on December 1, 2019, which marks the classified protection has been changed from 1.0 to 2.0.

3. Classified Protection 2.0 and Analysis Method

3.1. Comparative analysis of the standard of classified protection 2.0 and 1.0

Compared with the classified protection standard 1.0, the standard 2.0 have been adjusted in the following four aspects. First, the scope of protected objects are adjusted. The protection object is adjusted from the original narrow information system to basic information network system, cloud computing platform system, data system, Internet of things and industrial control system and so on. Second, the security requirements are refined into general security requirements and extended security requirements. Extended security requirements are divided into mobile Internet, cloud computing, Internet of things, industrial control and other aspects of the expansion requirements. Third, the classification in the original standard has also been adjusted. For example, "data security and backup and recovery" is adjusted to "security computing environment" and "security management center". Fourth, the safety control points S, A, G labeling are cancelled, some appendixes are added, and some application scenarios are described. In a word, the adjustment of the standard reflects the design concept of classified protection standard 2.0 has changed from passive defense to active defense.

3.2. Framework of classified protection 2.0

The classified protection standard 2.0 consists of general security requirements and extended security requirements. General security requirements are divided into technical requirements and management requirements. The technical requirements are composed of five parts, such as safety physical environment. And management requirements are also composed of five parts, such as safety management system.

Table 1. Framework of general security requirements.

Class one	Class two	Class three
general security requirements	technical requirements	Secure physical environment
		Secure communication network
		Secure zone boundary
		Secure computing environment
general security requirements	technical requirements	Secure management center
	management requirements	Secure management system
		Secure management organization
		Secure management personnel
		Secure construction management
		Secure operation and maintenance management

The extended security requirements are divided into four scenarios: cloud computing extended security requirements, mobile Internet extended security requirements, Internet of things extended security requirements and industrial control system expansion security requirements.

3.3. Analysis method and steps

Analysis method: According to the classified protection standard 2.0, the non-compliance points are found step by step.

Step 1: According to the *Information security technology — Classification guide for classified protection of cybersecurity*, analyse whether the protection class of business information system is appropriate.

Step 2: According to the *Information security technology — Evaluation requirement for classified protection of cybersecurity* and the *Information security technology — Testing and evaluation process guide for classified protection of cybersecurity*, analyses the technical requirements and management requirements, and finds out the non-compliance points of business information system in the general security requirements.

Step 3: According to *standards* of Step 2, analyses which application scenarios the business information system meets, and then analyses the non-compliance points of business information system in the extended security requirements.

4. Compliance Analysis

4.1. Analysis of protection class

In terms of business information security, when the business information is damaged, it will damage the legitimate rights and interests of citizens, legal persons and other organizations. The specific performance is: when the business information is destroyed, important data is deleted or tampered, it will have a serious impact on the normal work of the business department, resulting in the business department can not normally carry out or provide wrong services to the public. It causes serious damage to the legitimate rights and interests of citizens, legal persons and other organizations, so the security protection class of business information is set as class two.

In terms of system service security, when the system service is damaged, it will damage the legitimate rights and interests of citizens, legal persons and other organizations. The specific performance is: when the service can not be provided normally, it will have a serious impact on the normal work of the business department, resulting in the normal planning, soliciting contributions, editing, publishing and distribution of the publications. It causes serious damage to the legitimate rights and interests of citizens, legal persons and other organizations, so the security protection class of business information is set as class two.

The security protection class is determined by the higher class of business information security protection and system service security protection, so the business information system protection class is set as class two.

4.2. Analysis of technology part of general security requirements

According to the standard analysis, find out non-compliance points.

Table 2. Non-compliance points of technology part of general security requirements.

Requirements	Items	non-compliance points
Secure physical environment	Fire prevention in physical environment	Lack of system physical machine environment building material fire resistance rating description
Secure physical environment	Physical access control	The records of the work contents of relevant personnel contacting with the physical machine of the system are not detailed
Secure physical environment	Electromagnetic protection	The power cable and communication cable of the system physical machine are not isolated and laid
Secure communication network	Identification	The exchange attached to the server is not configured with password replacement cycle
Secure communication network	Identification	The switch attached to the server does not enable the login connection timeout exit function
Secure communication network	Transmission encryption	The data transmission is not encrypted
Secure zone boundary	access control	The security equipment on the system has not been decentralized and the default account has not been renamed
Secure zone boundary	Intrusion Prevention	No terminal access mode has been set for the security equipment attached to the system
Secure computing environment	Data integrity	No verification technology is used to ensure the data integrity in the communication process
Secure computing environment	Data backup and recovery	The backup function is not enabled for some data
Secure computing environment	Remaining information protection	It should be identified that the storage information is completely cleared before the storage space is released
Secure management center	access control	Account and authority should be assigned to the system login user
Secure management center	access control	Redundant and expired accounts should be deleted or stopped in time
Secure management center	security audit	The security audit function is not enabled
Secure management center	Malicious code prevention	No malware installed
Secure management center	Personal information protection	The user information should be encrypted and stored

4.3. Analysis of management part of general security requirements

According to the standard analysis, find out non-compliance points.

Table 3. Non-compliance points of management part of general security requirements.

Requirements	Items	non-compliance points
Secure management system	Review record of management system	Lack of review record of management system
Secure management system	Release record of management system	Lack of release record of management system
Secure management system	Revision record of management system	Lack of revision record of management system
Secure management organization	Staffing	System administrator, database administrator and security administrator are not equipped respectively
Secure management organization	Communication and cooperation	No minutes of communication between business system management department and network security department
Secure management organization	Audit and inspection	The regular inspection record of the system is not detailed
Secure management personnel	Personnel to leave the post	There is no record of authority granted or revoked by the person in charge of the system when leaving the post
Secure management personnel	Security training	There is no training record of safety awareness and knowledge of all kinds of personnel
Secure construction management	Security scheme design	No security scheme design
Secure construction management	Data backup and recovery	There are no demonstration and approval materials for safety scheme
Secure construction management	Software development	No malicious code detection or code audit report
Secure construction management	Test and acceptance	No security test report before launch
Secure operation and maintenance management	Asset management	Lack of necessary asset list
Secure operation and maintenance management	Equipment maintenance management	Lack of necessary maintenance records
Secure operation and maintenance management	configuration management	Lack of basic configuration information base
Secure operation and maintenance management	Emergency plan management	Lack of emergency plan for network security incidents
Secure operation and maintenance management	Emergency plan management	There is no emergency plan training, drill and record for relevant personnel

4.4. Analysis of management part of general security requirements

The business information system does not involve four scenarios of extended security requirements.

5. Categories of Non-compliance Points and Suggestions for Rectification

According to the actual situation, the difficulty of rectification of non-compliance points is analyzed one by one, and the non-compliance points are classified. It is mainly divided into three categories: immediate rectification, long-term rectification and no rectification.

Table 4. Categories of non-compliance points.

Categories	Items	non-compliance points
Immediate rectification	Electromagnetic protection	The power cable and communication cable of the system physical machine are not isolated and laid
Immediate rectification	Identification	The exchange attached to the server is not configured with password replacement cycle
Immediate rectification	Identification	The switch attached to the server does not enable the login connection timeout exit function
Immediate rectification	Transmission encryption	The data transmission is not encrypted
Immediate rectification	access control	The security equipment on the system has not been decentralized and the default account has not been renamed
Immediate rectification	Intrusion Prevention	No terminal access mode has been set for the security equipment attached to the system

Immediate rectification	Data integrity	No verification technology is used to ensure the data integrity in the communication process
Immediate rectification	Data backup and recovery	The backup function is not enabled for some data
Immediate rectification	Remaining information protection	It should be identified that the storage information is completely cleared before the storage space is released
Immediate rectification	access control	Account and authority should be assigned to the system login user
Immediate rectification	access control	Redundant and expired accounts should be deleted or stopped in time
Immediate rectification	security audit	The security audit function is not enabled
Immediate rectification	Malicious code prevention	No malware installed
Immediate rectification	Personal information protection	The user information should be encrypted and stored
Immediate rectification	Staffing	System administrator, database administrator and security administrator are not equipped respectively
Immediate rectification	Asset management	Lack of necessary asset list
Immediate rectification	configuration management	Lack of basic configuration information base
Immediate rectification	Emergency plan management	Lack of emergency plan for network security incidents
Long-term rectification	Physical access control	The records of the work contents of relevant personnel contacting with the physical machine of the system are not detailed
Long-term rectification	Review record of management system	Lack of review record of management system
Long-term rectification	Release record of management system	Lack of release record of management system
Long-term rectification	Revision record of management system	Lack of revision record of management system
Long-term rectification	Communication and cooperation	No minutes of communication between business system management department and network security department
Long-term rectification	Audit and inspection	The regular inspection record of the system is not detailed
Long-term rectification	Personnel to leave the post	There is no record of authority granted or revoked by the person in charge of the system when leaving the post
Long-term rectification	Security training	There is no training record of safety awareness and knowledge of all kinds of personnel
Long-term rectification	Equipment maintenance management	Lack of necessary maintenance records
Long-term rectification	Emergency plan management	There is no emergency plan training, drill and record for relevant personnel
No rectification	Fire prevention in physical environment	Lack of system physical machine environment building material fire resistance rating description
No rectification	Security scheme design	No security scheme design
No rectification	Data backup and recovery	There are no demonstration and approval materials for safety scheme
No rectification	Software development	No malicious code detection or code audit report
No rectification	Test and acceptance	No security test report before launch

The category of immediate rectification mainly includes policies that are not enabled, such as password replacement cycle control, account classification and authorization management, etc. These rectification items pay less cost and can be carried out in a short time. The category of long-term rectification mainly includes various kinds of records that are missing. These records need to strengthen the implementation of the system and form the work style according to the rules and regulations. The category of no rectification are mainly non-compliance points in system construction. The business information system construction is too early and lack of security scheme design. Rectification cannot be carried out.

6. Summary and Prospect

This article briefly introduces the research background, development status and importance of the classified protection of cybersecurity, as well as the difference between the standard 2.0 and 1.0. Combined with the actual business system, from the grading, evaluation, rectification and other work process analysis and carding, judge the protection class, find out the non-compliance points, classify the non-compliance points and put forward the rectification suggestions. Classified protection of cybersecurity is a grading system, even if there are deduction points, the enough total score can pass the evaluation.

More and more governments pay attention to cybersecurity, and the classified protection of cybersecurity was born under this background. However, cybersecurity protection cannot be comprehensive. Different systems, networks are differently protected for different importance, which can make the cybersecurity protection work more targeted, more effective. So that the business information system more secure operation.

References

- [1] Tian Lijia, Wang Guanghou. Research on the Status Quo of Chinese Cyberspace Security [J]. Journal of Shanxi Datong University (Social Science) , 2015(04):12-14+59.
- [2] Li Yang. Classification Protection of American Information System and Its Enlightenment to China from CNSSI 1253 [J]. Science and Technology of Secrecy, 2019(07):29-34.
- [3] Xu Zhen. Classified Protection of Cybersecurity: from 1.0 to 2.0 [J]. Information Security, 2019(07):63-64.
- [4] Liu Yanyun. Cybersecurity and Information Security Status and Countermeasures [J]. Journal of Jinan Vocational College, 2019(04):122-124.
- [5] GB/T 22239-2019, Information security technology — Baseline for classified protection of cybersecurity [S].
- [6] GB/T 22240-2020, Information security technology — Classification guide for classified protection of cybersecurity [S].
- [7] GB/T 28448-2019, Information security technology — Evaluation requirement for classified protection of cybersecurity [S].
- [8] GB/T 28449-2018, Information security technology — Testing and evaluation process guide for classified protection of cybersecurity [S].
- [9] GB/T 25070-2019, Information security technology — Technical requirements of security design for classified protection of cybersecurity [S].